



# Personal Data (Privacy) Ordinance and Electronic Health System

Points to Note for Healthcare Providers  
and Healthcare Professionals



PCPD



H K



[PCPD.org.hk](http://PCPD.org.hk)

個人資料私隱專員公署  
Office of the Privacy Commissioner  
for Personal Data  
中國香港 Hong Kong, China

# Personal Data (Privacy) Ordinance and Electronic Health System

## Points to Note for Healthcare Providers and Healthcare Professionals

The Electronic Health System Ordinance, Cap. 625 (“**eHealth Ordinance**”) provides a legal basis for the collection, sharing, use, and safekeeping of patients’ health data under the Electronic Health System (“**eHealth System**”). The eHealth System is an information infrastructure for healthcare providers (including doctors and other healthcare professionals) in both the public and private sectors to, with the consent of a patient, access and share the patient’s health record for healthcare-related purposes.

Healthcare providers may visit the website of the eHealth System ([www.ehealth.gov.hk](http://www.ehealth.gov.hk)) for more details.

### The Relationship between the Personal Data (Privacy) Ordinance and the eHealth System

Patients’ health records in the eHealth System amount to personal data, which is protected under the Personal Data (Privacy) Ordinance, Cap. 486 (“**PDPO**”). Healthcare providers and the Commissioner for the Electronic Health Record, as data users, should act in accordance with the requirements under the eHealth Ordinance as well as the PDPO (including the Six Data Protection Principles) when handling patients’ health records in the eHealth System.

The functions and powers of the Privacy Commissioner for Personal Data (“**Privacy Commissioner**”) under the PDPO in relation to personal data in the eHealth System include the following:

- ▶ handling complaints<sup>1</sup> of suspected breaches of the PDPO and initiating compliance checks or investigations if necessary;
- ▶ carrying out inspection of the eHealth System in respect of its handling of personal data;
- ▶ providing guidance on personal data privacy in relation to the eHealth System to healthcare providers and citizens; and
- ▶ handling any data breach notification in relation to the eHealth System.

The Commissioner for the Electronic Health Record has stated in the Code of Practice and Conditions of Registration for Healthcare Providers the requirements on protection of personal data in detail. Before registering with the eHealth System, healthcare providers should read the relevant provisions carefully. When exercising the functions and powers under the PDPO, the Privacy Commissioner will also take into account the Code of Practice issued by the Commissioner for the Electronic Health Record, in addition to the provisions of the eHealth Ordinance.

<sup>1</sup> Please refer to the Complaint Handling Policy issued by the PCPD ([https://www.pcpd.org.hk/english/complaints/policy/complaint\\_policy.html](https://www.pcpd.org.hk/english/complaints/policy/complaint_policy.html)).

## Points to Note for Healthcare Providers and Healthcare Professionals

### 1. Patients' participation and the giving of sharing consent

- 1.1. Health records are sensitive personal data. Healthcare providers should patiently explain the use of the eHealth System to patients in detail to ensure that patients understand the benefits of sharing their health records.
- 1.2. Healthcare providers should ensure that their staff will remind patients, before giving joining consent<sup>2</sup> and/or sharing consent<sup>3</sup>, to read carefully the "Personal Information Collection Statement", "Privacy Policy Statement", and "Participant Information Notice" issued by the Commissioner for the Electronic Health Record<sup>4</sup>.
- 1.3. Participation in the eHealth System is voluntary. A patient may withdraw from the eHealth System and/or revoke his/her sharing consent given to any healthcare provider<sup>5</sup> at any time. When patients express the above intention, healthcare providers should explain to them in detail the impact of such decisions on the healthcare service they receive.

### 2. Access to electronic health record ("eHR") on necessity basis

- 2.1. Healthcare providers must take reasonable steps to ensure that healthcare professionals may only have access to health records relevant to the healthcare service they provide under the "patient-under-care" and "need-to-know" principles. For example:
  - ▶ Set adequate but not excessive access rights to the data in the eHealth System in accordance with the functions and clinical needs of various healthcare professionals;
  - ▶ Incorporate the requirement of keeping patients' information confidential in staff manuals or codes of practice;
  - ▶ Review staff's access right to the data in the eHealth System regularly, and cancel that of departing staff as soon as possible.
- 2.2. Healthcare professionals must, even if already authorised by healthcare providers to access eHRs, exercise professional judgment to determine what exact data is necessary to be accessed for reference as actually needed in the provision of healthcare services.
- 2.3. Healthcare providers and healthcare professionals should properly handle patients' health records in the eHealth System and should not use the patients' personal data for new purposes (i.e. purposes other than those stated at the time of collection of personal data), for example, for uploading patients' health records to social media without their explicit and voluntary consent.

### 3. Data accuracy

Healthcare providers should ensure that the eHRs they provide to the eHealth System are accurate.

<sup>2</sup> A patient shall give joining consent to register with the eHealth System. Once the joining consent is given, healthcare providers may deposit his/her eHRs into the patient's eHealth System account. The patient is also taken to have given sharing consent to the Department of Health, the Hospital Authority, the Primary Healthcare Commission, and healthcare facilities managed or controlled by the Government, the Hospital Authority, or a Hospital Authority subsidiary (see Footnote 5).

<sup>3</sup> "Sharing consent" means that the patient agrees to let a particular healthcare provider access the eHR in the patient's eHealth account.

<sup>4</sup> The "Participant Information Notice" sets out the details of the eHealth System, including the background of the eHealth System, what joining consent and sharing consent are and how to give them, the sharable scope and use of eHRs, registration and withdrawal procedures of the eHealth System, procedures for revocation of sharing consent, etc.

<sup>5</sup> Managing sharing consent is not applicable to the Department of Health, the Hospital Authority, the Primary Healthcare Commission, or healthcare facilities managed or controlled by the Government, the Hospital Authority, or a Hospital Authority subsidiary (see Footnote 2).



## 4. Data security

- 4.1. Healthcare providers shall adopt all practicable steps to protect the personal data in the eHealth System. For example:
- ▶ Ensure that when authorised staff log into the eHealth System, eHRs shown on the computer screen will not be seen by unrelated third parties (e.g. consider configuring screen orientation and/or using a privacy filter);
  - ▶ Conduct risk assessment for devices if patients' eHRs in the eHealth System are accessed through notebook computers at non-registered locations for provision of healthcare services (e.g. consultation at patients' homes);
  - ▶ Keep eHRs downloaded or printed from the eHealth System (in paper or electronic form) safely, and formulate guidelines on the use of portable storage devices<sup>6</sup> to minimise the risk of personal data leakage;
  - ▶ Adopt appropriate measures to ensure that healthcare providers' information systems are adequately safeguarded and properly functioning to avoid jeopardising patients' eHRs in the eHealth System.
- 4.2. If there is a data breach of the eHealth System, healthcare providers should notify both the Commissioner for the Electronic Health Record and the Privacy Commissioner<sup>7</sup> as soon as possible.

## 5. Direct marketing

Regarding protection of the vast amount of personal data in the eHealth System, healthcare providers must note that using eHRs in the eHealth System for direct marketing is a criminal offence under the eHealth Ordinance. Additionally, if healthcare providers intend to use the personal data in their local systems for direct marketing, they must comply with the requirements under Part 6A of the PDPO<sup>8</sup>; otherwise they will likewise be committing a criminal offence.

## 6. Personal data privacy policy

Healthcare providers should formulate personal data privacy policies and review the policies periodically in order to state their arrangements for the uploading of patients' data from their own local system to the eHealth System<sup>9</sup>. Any updates to the policies should be appropriately indicated to patients.

## 7. Data access requests or data correction requests

- 7.1. As a healthcare provider is not entitled to provide a patient with an eHR uploaded to the eHealth System by any other healthcare provider, when a patient requests comprehensive access to his/her personal data in the eHealth System, healthcare providers should advise the patient to make a data access request to the Commissioner for the Electronic Health Record. Healthcare providers should reply to the patient in writing within 40 days as required under the PDPO<sup>10</sup>. Please note that the healthcare provider should ascertain the target and scope of the request. If a patient requests access to his/her personal data in an individual healthcare provider's

<sup>6</sup> Please refer to the "Guidance on the Use of Portable Storage Devices" issued by the PCPD ([https://www.pcpd.org.hk/english/resources\\_centre/publications/files/portable\\_storage\\_e.pdf](https://www.pcpd.org.hk/english/resources_centre/publications/files/portable_storage_e.pdf)).

<sup>7</sup> Please refer to the "Guidance on Data Breach Handling and Data Breach Notifications" issued by the PCPD ([https://www.pcpd.org.hk/english/resources\\_centre/publications/files/guidance\\_note\\_dbn\\_e.pdf](https://www.pcpd.org.hk/english/resources_centre/publications/files/guidance_note_dbn_e.pdf)).

<sup>8</sup> Please refer to the "Guidance on Direct Marketing" issued by the PCPD ([https://www.pcpd.org.hk/english/publications/files/GN\\_DM\\_e.pdf](https://www.pcpd.org.hk/english/publications/files/GN_DM_e.pdf)).

<sup>9</sup> Please refer to the "Guidance on Preparing Personal Information Collection Statement and Privacy Policy Statement" issued by the PCPD ([https://www.pcpd.org.hk/english/resources\\_centre/publications/files/GN\\_picspps\\_e.pdf](https://www.pcpd.org.hk/english/resources_centre/publications/files/GN_picspps_e.pdf)).

<sup>10</sup> Please refer to the Guidance Note on "Proper Handling of Data Access Request and Charging of Data Access Request Fee by Data Users" issued by the PCPD ([https://www.pcpd.org.hk/english/resources\\_centre/publications/files/dar2020\\_e.pdf](https://www.pcpd.org.hk/english/resources_centre/publications/files/dar2020_e.pdf)).



local system, the healthcare provider should comply with his/her request in accordance with the requirements of the PDPO<sup>11</sup>.

- 7.2. When a patient's request for correcting his/her personal data is received, the healthcare provider should, subject to the actual circumstances, comply with or refuse the request in accordance with the requirements of the PDPO<sup>12</sup>.
- 7.3. Healthcare providers should designate staff to handle data access or data correction requests, and provide proper training and guidelines to staff on the requirements of the PDPO.

## 8. Complaints

- 8.1. It is within the jurisdiction of the Office of the Privacy Commissioner for Personal Data (“PCPD”) to handle complaints relating to personal data in the eHealth System and possible contravention of the PDPO. Upon receipt of such complaints (irrespective of whether they are lodged with the PCPD directly or referred by the Commissioner for the Electronic Health Record), the PCPD will follow them up according to its Complaint Handling Policy.
- 8.2. To safeguard patients' health records in the eHealth System, the eHealth Ordinance has established offences relating to accessing, damaging, or modifying data in the eHealth System. As patients' health records in the eHealth System are personal data, a healthcare provider who commits the above offences may also contravene the Data Protection Principles and/or provisions of the PDPO. When such a complaint is received by the Privacy Commissioner and/or the Commissioner for the Electronic Health Record, who opines that an offence may have been committed under either or both Ordinances, the complaint will be referred to the Police for criminal investigation.

## Action List for Healthcare Providers when Joining the eHealth System for Protection of Personal Data Privacy

As a good practice, healthcare providers should review whether adequate measures have been adopted to safeguard personal data privacy when joining the eHealth System, including the following:

- ✓ Formulate/amend Personal Information Collection Statement
- ✓ Formulate/amend Personal Data Privacy Policy
- ✓ Set up and test basic facilities (including hardware and software), and conduct risk assessment for devices
- ✓ Provide training to staff on the operation and operating procedure of the eHealth System, and formulate relevant codes or guidelines
- ✓ Formulate policy on the handling of data access requests and data correction requests
- ✓ Develop procedures for handling complaints related to the eHealth System and the mechanism for notifying the Commissioner for the Electronic Health Record
- ✓ Set up a mechanism for the handling and notification of data breaches of the eHealth System

<sup>11</sup> See Footnote 10.

<sup>12</sup> Please refer to the “Guidance on the Proper Handling of Data Correction Request by Data Users” issued by the PCPD ([https://www.pcpd.org.hk/english/resources\\_centre/publications/files/dcr\\_e.pdf](https://www.pcpd.org.hk/english/resources_centre/publications/files/dcr_e.pdf)).



個人資料私隱專員公署  
Office of the Privacy Commissioner  
for Personal Data  
中國香港 Hong Kong, China



Tel : 2827 2827  
Fax : 2877 7026  
Address : Unit 1303, 13/F, Dah Sing Financial Centre,  
248 Queen's Road East, Wanchai, Hong Kong  
Email : [communications@pcpd.org.hk](mailto:communications@pcpd.org.hk)



PCPD Website  
[pcpd.org.hk](http://pcpd.org.hk)



Download this  
Publication



This publication is licensed under a Creative Commons Attribution 4.0 International (CC BY 4.0) licence. In essence, you are free to share and adapt this publication, as long as you attribute the work to the Office of the Privacy Commissioner for Personal Data, Hong Kong. For details, please visit [creativecommons.org/licenses/by/4.0](https://creativecommons.org/licenses/by/4.0).

## Disclaimer

The information and suggestions provided in this publication are for general reference only. They do not serve as an exhaustive guide to the application of the law and do not constitute legal or other professional advice. The Privacy Commissioner makes no express or implied warranties of accuracy or fitness for a particular purpose or use with respect to the information and suggestions set out in this publication. The information and suggestions provided will not affect the functions and powers conferred upon the Privacy Commissioner under the Personal Data (Privacy) Ordinance.

March 2026 (First Revision)